

ha.ckers.org web application security lab - Archive » Hacking Intranets Via Brute Force

ha.ckers.org web application security lab - Archive » Hacking Intranets Via Brute Force - Author not stated, ha.ckers.org.

- Published: date not stated
- Original: <<http://ha.ckers.org/blog/20061228/hacking-intranets-via-brute-force/>>
- Preserved from: <http://ha.ckers.org/blog/20061228/hacking-intranets-via-brute-force/> (stored) on 2026-08-06
- Capture timestamp: 20080112114305
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

ha.ckers.org web application security lab - Archive » Hacking Intranets Via Brute Force

[[image: image]](<http://ha.ckers.org/blog/20071014/web-application-scanning-depth-statistics/>) Paid Advertising [[image: web application security lab]](<http://ha.ckers.org/>)

Hacking Intranets Via Brute Force

I've been toying with Intranet hacking for a few years now, and I've always thought there were more creative ways to do that. One of which was by using JavaScript. Another that is less sexy but no doubt dangerous is direct brute force. One of the major issues with Intranets is that companies don't realize they need both an internal and an external DNS resolver. One for the public and one to hide the true IP address of their intranet applications. The obvious Intranet application that most companies have is an Intranet page. Usually it links the user to all the other wonderful applications that the company hosts.

Okay, well that's great, so it would seem that the Intranet isn't that interesting if it's only got a bunch of links. Well that's probably true except that knowing the links and knowing that the DNS resolver works for internal applications as well as external means that once you know the name you can start finding a lot more interesting websites on the internal site. Okay, so where do we find some vulnerable sites? Easy enough, let the Internet do some work for you. Let's start with a big list of sites (the Alexa 500 will do). Now let's scrape them and do a DNS lookup on each one looking for a few common key words "intranet" and "internal". Now let's do a reverse lookup and see what their IP address is. And here's our list:

10.0.1.10 intranet.godaddy.com 10.1.119.43 intranet.dyndns.org 10.210.136.22 internal.iask.com
10.25.0.31 intranet.joyo.com 10.30.100.238 intranet.shopping.com 10.50.11.131 intranet.monster.com
125.206.202.66 internal.hatena.ne.jp 125.206.202.66 intranet.hatena.ne.jp 192.168.11.6
internal.zhaopin.com 192.168.11.6 intranet.zhaopin.com 194.60.206.60 internal.facebook.com
194.60.206.60 intranet.facebook.com 200.225.157.127 intranet.ig.com.br 200.5.80.58 intranet.terra.com.ar
202.106.185.73 internal.126.com 202.106.185.73 intranet.126.com 202.108.253.57 internal.soufun.com
202.108.253.57 intranet.soufun.com 202.45.130.127 intranet.jobsdb.com 202.84.5.80 intranet.china.com
202.99.16.9 intranet.homeway.com.cn 204.9.178.60 internal.typepad.com 204.9.178.60
intranet.typepad.com 207.106.239.74 internal.aweber.com 207.106.239.74 intranet.aweber.com
207.46.78.170 internal.msn.co.jp 207.46.78.170 internal.msn.com.cn 207.46.78.170 internal.msn.com.tw
207.46.78.170 intranet.msn.co.jp 207.46.78.170 intranet.msn.com.cn 207.46.78.170 intranet.msn.com.tw
207.7.149.50 internal.bebo.com 207.7.149.50 intranet.bebo.com 208.66.64.173 intranet.technorati.com
209.183.200.52 intranet.freewebs.com 209.202.226.100 internal.tripod.com 209.202.226.100
intranet.tripod.com 209.8.50.54 internal.yousendit.com 209.8.50.54 intranet.yousendit.com 210.150.29.30
internal.exblog.jp 210.150.29.30 intranet.exblog.jp 211.100.6.30 internal.readnovel.com 211.100.6.30
intranet.readnovel.com 211.147.3.81 internal.it168.com 211.147.3.81 intranet.it168.com 211.151.252.189
internal.chinahr.com 211.151.252.189 intranet.chinahr.com 211.72.254.4 internal.yam.com 211.72.254.4
intranet.yam.com 212.126.20.1 internal.o2.pl 212.126.20.1 intranet.o2.pl 212.129.63.216
intranet.skyblog.com 212.129.63.231 internal.skyblog.com 212.31.2.5 intranet.hurriyet.com.tr
213.13.145.10 internal.sapo.pt 213.13.145.10 intranet.sapo.pt 213.136.52.34 intranet.mysql.com
213.180.193.24 internal.yandex.ru 213.180.193.24 intranet.yandex.ru 213.180.199.20 internal.narod.ru
213.180.199.61 intranet.narod.ru 213.54.164.169 internal.dyndns.org 216.128.27.100
internal.w3schools.com 216.128.27.100 intranet.w3schools.com 216.234.234.222 intranet.theplanet.com
217.148.176.63 internal.usercash.com 217.148.176.63 intranet.usercash.com 217.74.65.234
intranet.dev.interia.pl 218.244.111.214 internal.ctrip.com 218.30.64.121 internal.vnet.cn 218.30.64.121
intranet.vnet.cn 218.77.130.71 internal.tianya.cn 218.77.130.71 intranet.tianya.cn 218.93.205.59
internal.onlinedown.net 218.93.205.59 intranet.onlinedown.net 219.239.88.110 internal.yesky.com
219.239.88.110 intranet.yesky.com 219.239.94.46 internal.it.com.cn 219.239.94.46 intranet.it.com.cn
220.170.88.225 internal.mofile.com 220.170.88.225 intranet.mofile.com 222.185.229.78
internal.skycn.com 222.185.229.78 intranet.skycn.com 222.88.88.133 internal.51.la 222.88.88.133
intranet.51.la 38.118.213.25 intranet.filefront.com 59.106.28.143 intranet.seesaa.net 59.106.28.144
internal.seesaa.net 59.151.40.9 internal.wangyou.com 59.151.40.9 intranet.wangyou.com 59.188.4.76
internal.uwants.com 59.188.4.76 intranet.uwants.com 60.190.31.51 internal.51.com 60.190.31.51
intranet.51.com 60.191.254.47 internal.blogchina.com 60.191.254.49 intranet.blogchina.com
60.191.72.130 internal.5show.com 60.191.72.130 intranet.5show.com 61.129.48.152 internal.51job.com
61.135.134.206 intranet.focus.cn 61.135.134.216 internal.focus.cn 61.137.93.45 internal.5460.net
61.137.93.45 intranet.5460.net 61.151.243.133 internal.china.com 61.152.249.35 internal.1ting.com
61.152.249.35 intranet.1ting.com 61.31.193.111 internal.webs-tv.net 61.61.133.2 internal.twbbs.net.tw
61.61.133.2 intranet.twbbs.net.tw 62.129.129.27 internal.payserve.com 62.129.129.27
intranet.payserve.com 63.166.3.19 internal.wenxuecity.com 63.166.3.19 intranet.wenxuecity.com
63.236.2.233 internal.89.com 63.236.2.233 intranet.89.com 63.245.209.41 dyna-
intranet.nslb.sj.mozilla.com 64.124.63.70 internal.piczo.com 64.124.63.70 intranet.piczo.com
64.255.170.250 internal.wannawatch.com 64.255.170.250 intranet.wannawatch.com 64.56.205.72

internal.adultfriendfinder.com 64.56.205.72 intranet.adultfriendfinder.com 64.72.113.224
intranet.badongo.com 64.72.113.227 internal.badongo.com 65.64.83.190 internal.warriorforum.com
65.64.83.190 intranet.warriorforum.com 66.11.50.5 intranet.photobucket.com 66.11.54.5
internal.photobucket.com 66.152.91.81 internal.pornaccess.com 66.152.91.81 intranet.pornaccess.com
66.230.171.162 internal.xnxx.com 66.230.171.162 intranet.xnxx.com 66.246.179.201 intranet.multiply.com
66.246.179.202 internal.multiply.com 66.28.245.123 intranet.hi5.com 66.35.250.151 internal.slashdot.org
66.35.250.151 intranet.slashdot.org 69.20.16.232 internal.sitepoint.com 69.20.16.232
intranet.sitepoint.com 69.28.181.43 internal.deviantart.com 69.28.181.43 intranet.deviantart.com
69.36.233.10 internal.stumbleupon.com 69.36.233.10 intranet.stumbleupon.com 69.5.88.75
internal.megarotic.com 69.5.88.75 internal.megaupload.com 69.5.88.75 internal.sexuploader.com
69.5.88.75 intranet.megarotic.com 69.5.88.75 intranet.megaupload.com 69.5.88.75
intranet.sexuploader.com 69.59.144.138 internal.kooora.com 69.59.144.138 intranet.kooora.com
72.232.170.2 internal.4shared.com 72.232.170.2 intranet.4shared.com 72.232.72.218
internal.minijuegos.com 72.232.72.218 intranet.minijuegos.com 72.32.5.117 internal.break.com
72.32.5.117 intranet.break.com 8.10.160.60 internal.met-art.com 8.10.160.60 intranet.met-art.com
81.19.66.173 intranet.rambler.ru 88.212.196.65 internal.liveinternet.ru 88.212.196.65
intranet.liveinternet.ru

(Note: you aren't seeing redundant listings, they actually have different names "internal" and "intranet" even though they point to the same IP). Wow... I thought I'd find one or two, but 162 examples in the Alexa 500 alone! The ones with non-routable IP space like the 10.* and 192.168.* ones may still be interesting for anti-DNS pinning but let's ignore them for this conversation.

Now what are the chances all of those sites have secured their Intranets? Specifically how many do you think would shut down access to brute force attempts? We already know the usernames for those accounts, because they are almost always the NT domain usernames. Where would we find NT usernames out on the Internet? Well thankfully search engines have done the work for us here as they are almost always the same names as any public email addresses from those companies. IE: username@company.com is almost always the same as the NTDomain. Using this we can now brute force the Intranet website, with relative ease.

This entry was posted on Thursday, December 28th, 2006 at 3:53 pm and is filed under [Webappsec](#). You can follow any responses to this entry through the [RSS 2.0](#) feed. You can [\[leave a response\]\(\)](#), or [trackback](#) from your own site.

Leave a Reply Or Discuss [On the Forums](#)
